

Anexo K — Informe de seguridad

Generado desde el repositorio storyMaker · commit da1c8b6 · 2026-09-25 18:44 UTC · Qaracter group 2026

Análisis de seguridad (opcional O3): inyección de prompts, exfiltración entre novelas, rutas, presupuesto, dependencias y secretos. Informe completo: `docs/security-report.md`.

id	área	severidad	estado	resumen
SR-01	prompt injection	medium	CONFIRMED	every brief field except <code>free_text</code> reaches the orchestrator prompt verbatim, newlines included
SR-02	prompt injection	medium	CONFIRMED	the orchestrator's allowlist includes <code>Bash(python *)</code> and <code>Bash(node *)</code> , so a steered orchestrator can run arbitrary code
SR-03	prompt injection	low	CONFIRMED	the reader-change to (and the old fact text) is interpolated into the chapter-unit prompt
SR-04	path traversal	medium	CONFIRMED	profile from the request body is a filename: <code>../</code> escapes <code>config/profiles/</code> and any <code>*.json</code> can become the run's config, budget included
SR-05	budget	medium	MITIGATED 2026-09-24	POST <code>/api/runs/{id}/resume</code> starts each resume with a fresh budget: a \$1.00 ceiling allowed \$3.60 in a local check. The owner keeps the fresh ceiling per continuation (SPEC-007 §8) and adds a per-novel cap: Continue is re
SR-06	budget	low	CONFIRMED	the reader change and the judge spend outside the run's ceiling and outside the queue of one
SR-07	orphans	low	CONFIRMED	red-team cases 9 and 13: the shutdown hook covers a graceful stop only; the startup sweep does not check the pid
SR-08	PII	medium	CONFIRMED	the recipient alias is in the premise every orchestrator reads, contradicting "no model is given the recipient's name"
SR-09	PII	medium	CONFIRMED	the Langfuse export sends the premise (alias, memories, mandatory facts) to a third-party US host; the scrubber removes keys only
SR-10	path traversal	low	CONFIRMED	the slug is learned from model-written paths without validation; <code>..</code> is accepted
SR-11	input limits	low	CONFIRMED	brief string fields, tone, profile and reader to have no length limit; an unknown profile is a 500
SR-12	HTTP surface	low	NOT CONFIRMED	no auth and no Host-header check: a bodiless POST <code>.../halt</code> or <code>.../resume</code> is CSRF-able, and DNS rebinding could reach the API
SR-13	XSS	low	CONFIRMED	novel.html is served same-origin with text/html and no CSP; safe only while pdf.py is its sole writer
SR-14	supply chain	info	CONFIRMED	<code>.mcp.json</code> runs <code>@playwright/mcp@latest</code> , unpinned
SR-15	authorisation	info	CONFIRMED	POST <code>/run_id/changes</code> looks up <code>fact_usage</code> by <code>fact_id</code> without scoping it to <code>run_id</code>
SR-16	subprocess	info	CONFIRMED	NOVAFORGE_CHANGE_PROCEDURE_REV goes to git show unvalidated; a value starting with <code>-</code> is read as an option

- **Secretos en el historial:** revisados los dos repositorios; solo aparecen claves de prueba (`pk-lf-dum...`, `sk-lf-dum...`). Las credenciales se leen solo del entorno.
- **Sin API keys en ningún repo:** `.env.example` lleva las claves vacías.